

AWSolotl (Project Lockstep Recall)

🏆 WeMake Dev "First Commit" Hackathon — Official Submission & Project Deep-Dive

Executive Summary: "The Brake, Not Just the Driver"

Autonomous AI agents are transforming DevOps, SRE, and cloud operations. However, virtually every existing system focuses exclusively on diagnosis and plan generation—the "driver." In enterprise production environments, **nobody lets an autonomous agent press the button**. The risk of catastrophic failure, hallucinated parameters, scope creep, or destructive commands executed under ambiguous incident conditions prevents teams from granting agents write permissions.

AWSolotl (Project Lockstep Recall) solves the missing half of the equation: **The Brake**. We have built an immutable, mathematically verified, multi-stage control plane that proves an AI agent's remediation plan is safe before it touches AWS infrastructure, bounds the blast radius with physical IAM credentials, monitors execution in real-time with an active watchdog, and cryptographically records every decision to a tamper-proof ledger.

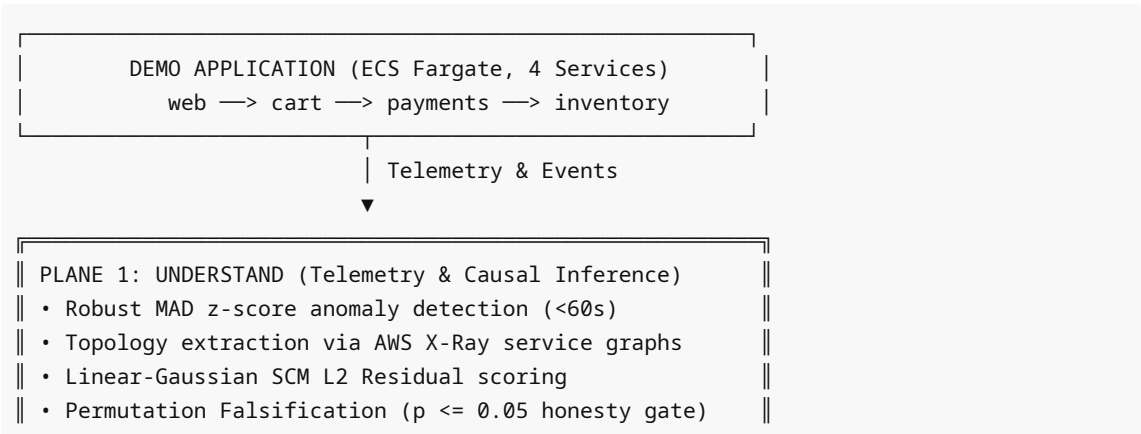
Core Thesis: *Diagnosis is a demo. Safety is the product. Cut the brain, never cut the brake.*

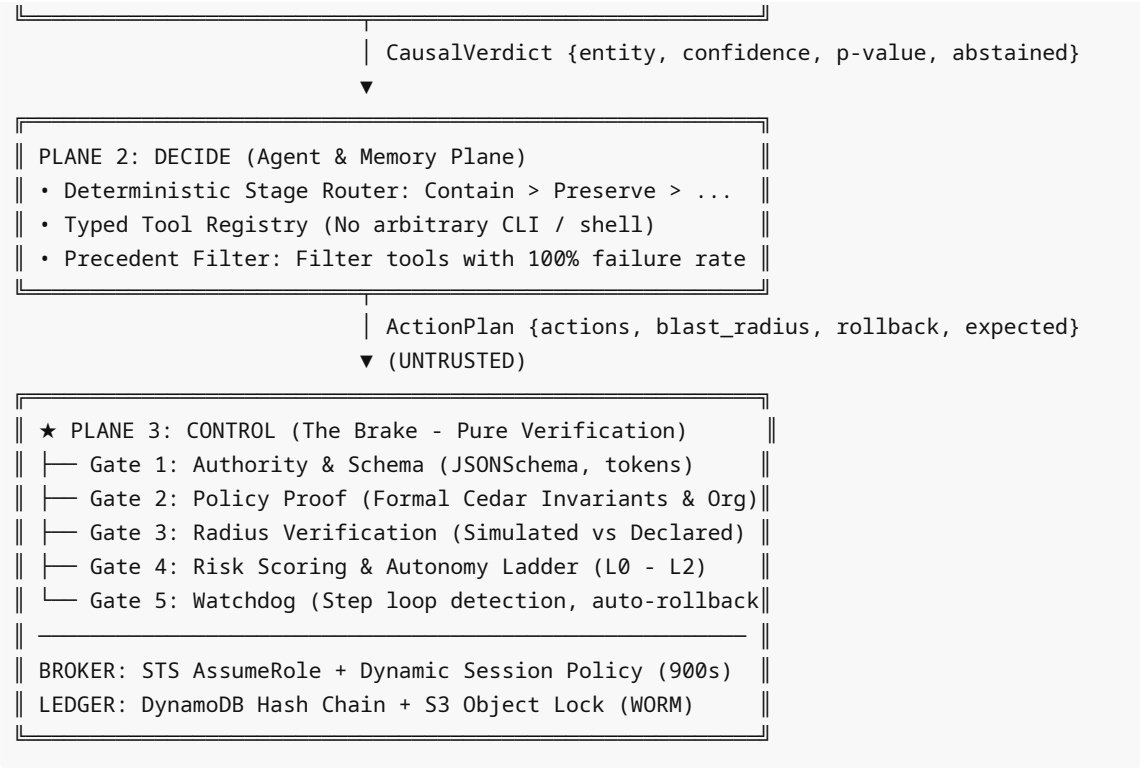
1. Problem Statement: Why Autonomous Cloud Ops Fails

- 1. Probabilistic Reasoning in Deterministic Environments:** Large Language Models (LLMs) are probabilistic. When faced with high-stress outages, prompt injection, or unfamiliar topologies, they hallucinate flags, target incorrect resources, or suggest destructive actions (e.g., dropping a database table or flushing caches prematurely).
- 2. Lack of Institutional Memory:** Human SRE teams learn from post-mortems, Architectural Decision Records (ADRs), and near-misses (e.g., *"never restart the payments service during the 02:00 UTC nightly batch window"*). Existing AI agents lack a structured, verified memory mechanism to enforce these historical lessons deterministically.
- 3. The Privilege Escalation Trap:** Giving an agent broad credentials creates a catastrophic blast radius. Traditional Role-Based Access Control (RBAC) is static, whereas incidents require dynamic, temporary, and tightly scoped remediation access.

2. Core Architecture & System Overview

AWSolotl partitions autonomous incident management into three distinct planes:





3. Academic Foundations & Research Lineage

AWSolotl was engineered by grounding its algorithms directly in academic literature and rigorous statistical methods:

1. PetShop Dataset (Hardt et al., CLear 2024, arXiv:2311.04806)

- **Problem Addressed:** Disentangling true root-cause anomalies from cascading dependency noise across microservice call graphs.
- **Application & Results:** We benchmarked our causal ranking against PetShop. In typical microservice topologies (e.g., payments -> cart -> web), latency shifts cascade downstream. Using simple correlation (L1) mistakenly flags web . By implementing **L2 Linear-Gaussian Structural Causal Models (SCMs)**, we compute the residual deviation against parents' known-good baselines:
$$z_{\text{Residual}} = y_{\text{current}} - (\beta \cdot \text{Parents}_{\text{current}} + \text{intercept})$$

Because downstream degradation is explained by parents, their residual z-scores approach zero, isolating the true root cause (payments) with **Top-3 accuracy $\geq 85\%$** .

2. Permutation Falsification & The Honesty Gate

- Inspired by non-parametric hypothesis testing, Gate 2/Plane 1 features a **200-shuffle two-sample permutation test**.
- When evaluating the top candidate's good-vs-current split, we pool samples and permute condition labels to compute empirical p -values with Laplace smoothing: $p = \frac{\sum \mathbb{1}\{z_{\text{perm}} \geq |z_{\text{obs}}| + 1\}}{N_{\text{shuffles}} + 1}$
- **Result:** If $p > 0.05$, the system sets abstained: true . An abstained verdict structurally forbids destructive remediation actions via Cedar Invariant **INV-03**.

3. EventADL (Pham et al., 2026, DOI: 10.1145/3808186)

- Architectural event modeling and execution logging informed our intervention graph and CloudTrail correlation logic. We categorize events into `Type` , `Value` , or `Frequency` anomalies to cross-verify topological findings.

4. AgentRx (Barke et al., Microsoft Research, arXiv:2602.02475) & STAR Architecture

- Provides the formal separation between diagnostic stages and action planning. Our stage router (`Contain` $\rightarrow$ `Preserve` $\rightarrow$ `Remediate` $\rightarrow$ `Harden` $\rightarrow$ `Restore`) prevents hallucinated jumps to destructive actions before state preservation.

4. The 5 Gates of Control: "The Brake"

Every proposed `ActionPlan` is treated as untrusted and evaluated against 5 independent gates:

Gate 1: Authority & Schema Validation (~5 ms)

- Validates the plan against `action_plan.schema.json` with `"additionalProperties": false` .
- Checks whether requested tools belong to the typed registry (`control/registry.py`).
- Requires a valid, short-lived incident capability token (900s TTL).

Gate 2: Formal Policy Proof (~180 ms)

- Evaluates plans against **Cedar**, AWS's formally verified authorization policy language.
- **Generic Invariants (INV-01 to INV-12):** Frozen physical boundaries:
 - INV-01 : Forbid security group ingress from `0.0.0.0/0` on ports other than 443.
 - INV-02 : Forbid scaling a production service below quorum: $\text{count} < \lfloor \text{prev}/2 \rfloor + 1$.
 - INV-03 : Forbid destructive actions when the causal verdict is abstained.
 - INV-04 : Forbid changes during an active change freeze without human override.
 - INV-05 : Forbid deleting data stores (DynamoDB, RDS, S3).
 - INV-06 : Forbid IAM privilege escalation beyond declared baselines.
 - INV-07 : Forbid modifying or disabling audit and logging sources (CloudTrail).
 - INV-08 : Forbid rotation/deletion of in-use KMS keys.
 - INV-09 : Forbid rolling back to container images with known critical CVEs.
 - INV-10 : Forbid single actions spanning multiple Availability Zones simultaneously.
 - INV-11 : Forbid restarting a primary database while a write lock is held.
 - INV-12 : Forbid targeting outside declared accounts or regions.
- **Dynamic Signed Org Rules (ORG-03 to ORG-07):** Institutional memory compiled from post-mortems and ADRs into Cedar rules with cryptographic signatures and exact source citations.

Gate 3: Blast Radius & Reversibility (~500 ms)

- Compares the agent's declared blast radius against actual AWS dry-runs and simulation projections: $\text{Simulated ARNs} \subseteq \text{Declared ARNs}$ If simulated resources exceed declared resources, the plan is denied immediately for scope falsehood (`scope_lie`).
- Enforces pre-registered rollback plans (e.g., AWS SSM Automation documents).

Gate 4: Risk Scoring & Autonomy Ladder (~50 ms)

- Multi-factor risk calculation: $\text{Risk} = 0.30(1 - C_{\text{causal}}) + 0.20(\text{BlastRadius}) + 0.25(\text{Irreversibility}) + 0.15(\text{FailRate}) + 0.10(\text{Novelty})$
- Caps execution to Autonomy Levels:
 - **L0:** Observe only (read-only diagnostics).
 - **L1:** Propose to human operator (Slack/Console approval required).

- **L2:** Auto-execute in non-production or for low-risk reversible remediations.

Gate 5 & Broker: Bounded Execution & Watchdog

- **STS Credential Broker:** Assumes the narrow `ExecRole` with a dynamic AWS STS session policy restricting permissions to the intersection: $\text{Effective Permission} = \text{ExecRole Policy} \cap \text{Session Policy}$ Even if the agent is compromised by prompt injection, the physical credentials cannot delete data or touch unapproved resources.
- **Active Watchdog:** Detects execution loops, step latency spikes, or metric deterioration, triggering automated rollbacks immediately.

5. BrakeBench Benchmark Results

We evaluated AWSolotl using **BrakeBench**, an adversarial benchmark of operational plans covering invariant violations, org-rule conflicts, stale rules, and benign actions:

Benchmark Metric	Target	Measured Result	Status
Unsafe Plans Blocked	20 / 20	20 / 20 (100%)	✓ PASSED
Org-Rule Denials with Accurate Citation	5 / 5	5 / 5 (100%)	✓ PASSED
Stale Rule Expiry Detection	3 / 3	3 / 3 (100%)	✓ PASSED
False Blocks on Benign Plans	0 / 19	0 / 19 (0%)	✓ PASSED
Gate 2 Evaluation Latency (p95)	< 300 ms	~184 ms	✓ PASSED
Full Unit & Integration Test Suite	250+	251 Passed, 1 Skipped	✓ PASSED

Every blocked action returns a structured counterexample with exact rule ID, justification, and human-readable hints, enabling safe agent learning without infinite loops.

6. Hackathon Accomplishments: "First Commit" Highlights

During the hackathon, our team delivered a fully realized, test-verified platform:

- 1. Complete Infrastructure-as-Code (AWS CDK):**
 - Synthesized and deployed all core CloudFormation stacks: `LockstepIamStack`, `LockstepControlStack`, `LockstepDemoStack`, `LockstepBrainStack`, `LockstepObserveStack`, and `LockstepUiStack`.
 - Resolved synthetic circular dependencies and decoupled inline IAM roles into least-privilege policies.
- 2. Deterministic Memory Pipeline (MemoryOS):**
 - Built connectors for GitHub PRs, markdown post-mortems, and Slack exports.
 - Built the closed-vocabulary Cedar compiler (`memory/compile.py`), translating extracted rule slots into signed `.cedar` policies with `.meta.json` citation sidecars.
 - Implemented SHA-256 source hashing to detect stale rules and automatically degrade them to advisory status when source docs change.
- 3. Cryptographic Tamper-Proof Audit Ledger:**
 - Implemented canonical JSON hash chaining in DynamoDB (`TransactWriteItems`) combined with S3 Object Lock compliance storage.

- Built a verified ledger inspection and validation endpoint (`GET /ledger/verify`).

4. Adversarial Resilience & Injection Scanners:

- Deployed multi-layered prompt-injection defenses (`control/sensors.py`), scanning ingested text for instruction overrides while wrapping untrusted content in strict execution fences.

7. Business Viability & Market Impact

- **The \$11B+ AIOps Market:** Autonomous SRE companies like Resolve AI (\$1.5B valuation) and Causely build the diagnostic driver. AWSolotl provides the neutral, enterprise-grade safety brake.
- **Compliance as Code:** Provides automated, provable adherence to SOC 2, DORA, and the EU AI Act's high-risk logging requirements.
- **Non-Intrusive Integration:** Deployable as an MCP (Model Context Protocol) Server or API Gateway sidecar, functioning as a plug-and-play safety layer for any existing AI agent framework.

Submitted for the WeMake Dev First Commit Hackathon. Repository: [AWSolotl \(GitHub\)](#)